

en no longer needed.

- Google (for GitLab.com) and AWS (for GitLab Dedicated) are responsible for implementing controls to manage physical and logical access to the servers and supporting infrastructure, underlying network and virtualization management software for its cloud hosting services where GitLab processing systems reside.
- Customers may elect to implement technical and organizational measures in relation to customer owned (Red) data.

Resources

For additional details and supporting artifacts please see GitLab's Customer Assurance Package.

SECTION: security/security-assurance/technical-security-validation.md

Technical Security Validation (TSV)

The Technical Security Validation (TSV) process is a partnership between GitLab's Security Risk and Security Research teams, designed to supplement TPRM procedures performed during software procurement. While the TPRM process serves to validate the design and operating effectiveness of a company's internal controls, the TSV is leveraged to perform additional due diligence around high risk systems such as those associated to a Security Notice. These procedures align with Security's Post Implementation Checklist, which serves as an attestation from the Business Owner that appropriate controls have been established by GitLab to secure third party systems.

The output of the TSV, such as conclusions on control deficiencies or opportunities for mitigation, are presented to the system's Business Owner to support informed purchasing decisions and completion of remediation steps where necessary.

TSV Workflow

A TSV is opened upon identification of control gaps or failures identified during a TPRM review in order to better understand their severity and to identify compensating controls where possible. Necessity of a TSV is determined based on the nature of deficiencies identified, data transmitted, and criticality of the system.

Upon creation of the TSV, the Business Owner is required to provide necessary documentation, systems access, and support as requested within the TSV issue. Once these items are reviewed by the TSV engineer, additional evidence or system access may be required to support these procedures. Provision of these items within a timely manner is critical to support this effort, and failure to provide them in a timely manner may result in escalations as defined below.

Once the TSV has been completed, the conclusion of the evaluation will be documented within the comments section of the TSV issue, with the Business Owner tagged. If adverse findings are identified, the Business Owner is responsible for acknowledging these findings and actioning them where possible. If no findings are identified, the issue will be closed and the Business Owner will be tagged for visibility.

Evidence Requests and Escalations

> Continued, timely collaboration between TPRM, the TSV engineer, and the Business Owner is required to support these procedures and allow for efficient completion of the TSV. The timelines below are defined with consideration to the priorities of all involved parties.

Initial Evidence Request

Steps necessary to begin the TSV are listed within the TSV Issue Template and include requests for items such as relevant product documentation, links to related issues, and provisioning of system access.

Items requested within the template must be provided within five business days of request submission. Failure to provide these items may result in management escalation by the Security Risk Engineer.

Supplemental Requests

Depending on the complexity of the system, additional items may be required by the TSV engineer to support these procedures, and may be requested via the issue comments.

Business Owners are asked to provide supplemental evidence, if needed, within five business days of the request. Failure to meet this timeline may result in management escalation by the TSV engineer.

Service Level Agreements (SLAs) & Responsibilities

The below-defined Service-Level Agreements and Responsibilities are in place to ensure timely completion of all necessary items within the TSV process.

The Security Risk Engineer opening the TSV is responsible for ensuring initial evidence requests are fulfilled in a timely manner, adhering to the escalation procedures defined above. Escalations will be performed after ten business days of inaction by the Business Owner, with follow-ups performed weekly thereafter until all items are provided. The TSV engineer will follow the above-defined escalation process for supplemental evidence requests. Following submission of all requested evidence, the Technical Security Validation will be completed within ten business days.

DRI	Action	Time to Complete	
-----	-----	-----	
Business Owner	Provide supporting evidence	5 business days from each request	
TSV Engineer	Complete TSV	10 business days from all evidence provided	

Resources

- GitLab's Integrated Third Party Risk Management (TPRM) Program

- Third Party Minimum Security Standards

- GitLab's Security Research Team

- TSV Project Workspace

SECTION: security/security-assurance/field-security/_index.md

Governance and Field Security team charter
{.h2}

<i class="fas fa-bullseye" style="color:rgb(110,73,203)" aria-hidden="true"></i> Field Security Team

The Field Security team serves as the public representation of GitLab's internal Security function. Our vision is to be the leading example in collaborative and transparent Customer Assurance Programs. Our mission is to empower the GitLab community with confidence and trust that their data is protected with high levels of security assurance to drive revenue growth. We partner with our fellow GitLab team members and customers to provide a pathway to yes!

<i class="far fa-lightbulb" style="color:rgb(110,73,203)" aria-hidden="true"></i> Core Competencies

The Field Security team is tasked with providing high levels of security assurance to internal and external customers. We work with all GitLab departments to document requests, analyze the risks associated with those requests, and provide value-added remediation recommendations. We do this in four main ways:

- Conducting Customer Assurance Activities such as completing Security, Privacy, and Risk Management Questionnaires, assisting in Contract Reviews, participating in Customer Pre-Sales Meetings, and making available our Security Documents (such as GitLab's SOC2 or Penetration Test reports). These activities are managed through the Customer Assurance Activities Service Desk.
- Proactively maintaining self-service security and privacy resources including the SafeBase Trust Center and the Knowledge Base.
- Providing recommendations based on customer security concerns in support of revenue growth through the annual Field Security Study and participation in the Quarterly Business Review Process.
- Building the GitLab Security brand by improving internal and external awareness of GitLab's security practices and the security of our platform. Engaging with customers and prospects through Evangelism Activities and with internal stakeholders via the Field Security Sales Training Program.

<i id="biz-tech-icons" class="fas fa-tasks"></i>Metrics and Measures of Success

Security Impact on Net ARR

<i class="fas fa-id-card" style="color:rgb(110,73,203)" aria-hidden="true"></i> Contact the Team

Ayoub Fandi, @ayofan, Staff Security Assurance Engineer, Field Security

- Customer Assurance Activities
- Evangelism

- Collateral Development for the Trust Center
- Field Security Sales Training Program
- Customer Engagements
- Contract Reviews
- Trust Center administration, maintenance and development (Knowledge Base, content, documents, integrations and metrics)

Jonathan Snow, @jgsnow, Senior Security Assurance Engineer, Field Security

- Customer Assurance Activities
- Trust Center maintenance and development (Knowledge Base, content, documents, integrations and metrics)

Joe Longo, @jlongogitlab, Senior Manager, Governance and Field Security

- Customer Assurance Activities
- Field Security Study
- Independent Security Assurance
- Contract Reviews
- Trust Center administration and development (Knowledge Base, content, documents, integrations and metrics)

{{% note %}}

The areas above related to each team members primary responsibility. However, each team member is cross trained in all processes and provide back up to each other if applicable.

{{% /note %}}

- GitLab Issues
 - /gitlab-com/gl-security/security-assurance/field-security-team
- Email
 - security-assurance@gitlab.com
- Slack
 - Group Handle
 - @field-security
 - Primary Slack Channels
 - sec-fieldsecurity
 - sec-assurance

Feedback and the Future of Field Security

Do you have an idea, feedback, or recommendation for how Field Security can better support you? Please open a General Request issue in the Field Security Project.

<i class="fas fa-book" style="color:rgb(110,73,203)" aria-hidden="true"></i> References

- Customer Assurance Activities Procedure
- Trust Center
- RFP Completion
- Knowledge Base
- Field Security Study

- Evangelism
- Field Security Sales Training Program
- Independent Security Assurance
- Security Shadow Program

```
<div class="d-grid gap-2 my-4">
<a href="/handbook/security/security-assurance/" class="btn bg-primary text-white btn-
lg">Return to the Security Assurance Homepage</a>
</div>
```

```
---
## SECTION: security/security-assurance/field-security/answerbase_quality_guide.md
```

Purpose

The purpose of this guide is to establish quality expectations for AnswerBase.

Quality Expectations

Answers

Answers in AnswerBase should have the following characteristics:

- More than just a yes or no answer
 - Answers should contain a supporting narrative.
 - The supporting narrative should accurately explain why we are answering yes or no to a question.
 - The supporting narrative should refer back to a control, product feature, policy/procedure, etc. that justifies our yes or no answer.
 - We are not obligated to provide the supporting narratives to customers in questionnaires.
 - The supporting narratives will enhance all team members' understanding of the topics covered by the answers.
 - The supporting narratives will help establish AnswerBase as a true knowledgebase for all team members.
 - Answers will be reviewed for accuracy on at least an annual basis.

Tags

- Answers should have tags assigned to them.
 - Tags will support quicker and smoother searching for team members.
 - Tags will be reviewed for accuracy on at least an annual basis.

Libraries

- Libraries should have appropriate names and descriptions assigned to them.
 - The names should describe the nature of the answers contained within each library.
 - The descriptions should further describe the nature of the answers contained within each library so every team member accurately understands what they are viewing when they enter a

library.

- Libraries that are not populated with content should have (COMING SOON) appended to the library name.

- Library owners should represent the SME responsible for maintaining the library.

- The justification for a library's existence should be evaluated on an annual basis.

- Libraries should be decommissioned when their existence is no longer justified.

- Libraries should have a decommissioned date, which should be communicated through the library description. Example:

This library is set for decommissioning on YYYY/MM/DD Description of Library

- The decommissioned date should be 30 days after a library is determined to be unjustified.

SECTION: security/security-assurance/field-security/customer-security-assessment-process.md

<link rel="stylesheet" type="text/css" href="/stylesheets/biztech.css" />

If you would like to request security collateral which are under NDA, (such as SOC 2 Type 2, Pentest executive summary, etc.) please visit the Trust Center and click on the request access button at the top right-hand corner.

Submit a Request

Customer Call Request

General Request

Contract Review Request

The above are for GitLab Team Members only. Customers should contact their GitLab Account Owner to initiate their requests. If a customer doesn't know their Account Owner or does not yet have an assigned Account Owner, they can contact the sales team. Once you have submitted the issue, it is now in our queue and will be assigned to one of our Field Security Engineers when it is next up (please see SLA's listed below).

Customer Assurance Activity Requests Overview

It's no surprise that GitLab Customers and Prospects conduct Security due diligence activities prior to contracting with GitLab. We recognize the importance of these reviews and have designed this procedure for GitLab Team Members to request Customer Assurance Activities.

GitLab Team Members

We will start all CAA requests (with the exception of Contract Reviews) by sharing the Trust

Center with the customer. The Trust Center will answer many of the customer's questions and will enable us to provide the customer with a more efficient and comprehensive experience.

Please do not assign the issue. Field Security will assign the issue to the appropriate team member. Thank you!

Accessing the Trust Center

To access GitLab's Trust Center:

- Navigate to trust.gitlab.com
- Click "Get Access" in the top right corner
- Enter your email address, and click "Continue"
- Do not click "Log into GitLab's workspace. That is for the admin portal.

The process is exactly the same for customers. If customers do not want to sign the click-wrap NDA, and they already have a fully-executed NDA in SFDC or an active GitLab subscription, we can bypass the click-wrap NDA on our end. Please note, this should be a last resort, as it will further delay their access to the trust center. The fastest way to drive customers towards success is to encourage them to leverage the self-service nature of the trust center to its fullest extent. If you have any questions, please reach out in the sec-fieldsecurity Slack channel.

For Questionnaires

The process will be handled in SafeBase. Customers/prospects who have access to the Trust Center can directly upload questionnaires by clicking the Submit a Questionnaire link at the top of the Trust Center.

Field Security has certain thresholds when determining when, and to what extent, we will complete custom security review questionnaires from customers. Field Security will consider completing questionnaires as detailed here in the Internal Handbook.

For Customer Calls and General Requests

Please use the Customer Call Request or General Request buttons above and follow the instructions.

- Be sure to include all requested information to expedite the process.
- ARR or potential ARR is required
- Customer calls require a preview of the topics the customer would like to cover to ensure we bring in any required subject matter experts for the call.
- If you are unsure of which type it is, please include as much information as you can and our team will adjust as needed.

For RFP completion

Please follow the directions above for submission, and for more information about our RFP process please view our RFP page [here](#).

For Contract Reviews

Please use the Contract Review Box above and follow the instructions.

Collaborate with Field Security

The Field Security Team also maintains the following resources for GitLab Team Members to collaborate with us!

[Customer Feedback](https://gitlab.com/gitlab-com/gl-security/security-assurance/field-security-team/field-security/-/issues/new?issuabletemplate=customer%20feedback)

[Internal Feedback](https://gitlab.com/gitlab-com/gl-security/security-assurance/field-security-team/field-security/-/issues/new?issuabletemplate=internal%20feedback%20request)

[Collateral Request](https://gitlab.com/gitlab-com/gl-security/security-assurance/field-security-team/field-security/-/issues/new?issuabletemplate=capcollateralrequest)

[Ad Hoc Request](https://gitlab.com/gitlab-com/gl-security/security-assurance/field-security-team/field-security/-/issues/new?issuabletemplate=adhocfieldsecurityrequest)

Knowledge Base

For information on how Field Security uses SafeBase and how it can support your workflows, please visit our Knowledge Base page.

Feedback from Field Security

The Field Security Team has the unique privilege of conversing with and receiving feedback from both customers and fellow GitLab team members. To ensure we always support our customers, Field Security follows GitLab's observation creation procedure to relay customers' requirements or concerns internally to the appropriate teams. To proactively request feedback from Field Security, use the Internal Feedback button to open a request.

Note: Field Security's observations must follow the Field Security Observation and OFI Quality Guide

Public Documentation

- Search for General Information about GitLab in our public handbook.
 - Review GitLab's Product Security Documentation.
 - Review GitLab's Trust Center and download publically available security assurance documents.
- To request our NDA Required documents, such as our SOC2 report, utilize the Request Access button in the Trust Center.

Self-Attestations

In the spirit of iteration, GitLab is continuously evolving our list of compliance self-attestations. Completed self-attestations are reviewed annually for continued applicability and can be found in our Trust Center. Customers can submit suggestions and requests for new self-attestations through their Account Manager. GitLab team members can submit recommendations for future compliance assessments through the Regulatory Security Compliance Feedback and Field Research epic.

Service Level Agreements

- Security Questionnaires: 10 Business Day. SA or CSM will utilize the Knowledge Base and/or other self-service resources prior to requesting Field Security assistance. SA or CSM will ensure everyone on the Field Security team has access to any files or portals.
- Contract Reviews: 5 Business Days. Field Security must be engaged in all relevant Contract Reviews.
- Customer Calls: SA or CSM will provide context to the Customer or Prospects questions or concerns prior to the meeting. Field Security will provide a PowerPoint presentation with critical information about GitLab Security and specifics to the Customer or Prospect's request. Field Security must be invited to all relevant Customer Meetings.
- Security Documents: Managed through the Trust Center. Create a General Request for unique enquiries that can't be satisfied through the Trust Center.

Exceptions

If the Account Owner or Customer Success point of contact feel they have sufficient knowledge and resources to complete a Customer Assessment, this procedure does not have to be used. These exceptions will not be tracked.

```
<div class="d-grid gap-2 my-4">  
<a href="https://handbook.gitlab.com/handbook/security/security-assurance/field-security/"  
class="btn bg-primary text-white btn-lg">Return to the Field Security Homepage</a>  
</div>
```

SECTION: security/security-assurance/field-security/evangelism.md

Why do we evangelise?

One of Field Security's critical missions is to improve internal and external awareness of GitLab's security practices and the security of our platform. As we continue to iterate and grow, we must improve our ability to engage and impact prospects and customers in a meaningful way.

Security evangelism allows us to develop a better understanding of our prospects' and customers' "needs" and "wants", and it allows us to better position ourselves to provide them with a valuable product and service.

How do we evangelise?

Field Security's goal is to take a holistic approach to security evangelism. We want to be

dynamic and transcend traditional methods of gathering and sharing information.

Written engagements

- An annual Field Security Study that documents areas of concern or improvement identified for GitLab's products and services.
- Whitepapers and collaterals
- Blog posts
- Surveys

Audio & video engagements

- Webinars
- Podcasts
- Videos

Live engagements

- Customer meetings
- Conferences (Information gathering and speaking engagements)
- Roadshows

How can you help?

Continuous and open feedback from all of our team members is more than appreciated. If you're interfacing with a prospect or a customer and you learn of a concern, a suggestion, a "want" or a "need", please forward that information to Field Security. Your feedback will help drive our roadmap and strategy so that we can help GitLab deliver more value to our customers and the industry.

Contact

To contact Field Security, please tag @field-security, or send us a message in Sec-Fieldsecurity.

SECTION: security/security-assurance/field-security/field-security-research-program.md

Why a Research program?

One of Field Security's critical missions is to impact the broader security industry through thought leadership. As the leader in DevSecOps and a key player in the security industry, GitLab is working on ensuring its internal security expertise is leveraged to improve security standards.

How ?

Field Security's goal is to take a holistic approach to security outreach. We want to be dynamic and transcend traditional methods of gathering and sharing information.

Outreach engagements

- Answering Requests for Comments/Information from throughout the security industry
- Participating in Industry Security Working Groups
- Communicating with Industry bodies and institutional Security agencies.
- Reflecting on regulation, standards and frameworks impacting security of customers

How can you help?

Continuous and open feedback from all of our team members is more than appreciated. If you're interfacing with a prospect or a customer and you learn of a concern, a suggestion, a "want" or a "need", please forward that information to Field Security. Your feedback will help drive our roadmap and strategy so that we can help GitLab deliver more value to our customers and the industry.

Contact

To contact Field Security, please tag @field-security, or send us a message in Sec-Fieldsecurity.

SECTION: security/security-assurance/field-security/field-security-rfp.md

Request for Information / Details

If a customer, or potential customer, has questions related to Product, Marketing, Legal and/or Environmental, Social and Governance (ESG)--including for renewals or during an active term--please follow the Request for Proposal (RFP) Process below.

Request for Proposal (RFP) Process

The Field Security Team, Legal & Corporate Affairs, Field Ops and Sales have created a process to assist and simplify the Request for Proposal or Information process for the Field Team. With regards to RFP's, the Field Team should follow the below steps:

1. Upon receipt of a Request for Proposal (RFP) or Request for Information (RFI), the Sales Team Member should ensure that an Account and Opportunity are created in SFDC;
1. If the RFP will require more than a quote being created (e.g. insight and assistance from various stakeholders), the Sales Team Member should request and receive ASM (or higher) approval via Chatter in the SFDC Opportunity.
1. The Sales Team Member will review content in GitLab's Trust Center Knowledgebase for any questions related to Security, Corporate, Privacy, Commercial Legal, and ESG. NOTE: All Team Members have a base-line entitlement.
1. Sales Team Member should engage Deal Desk, per standard process, for any question related to pricing and/or quoting.
1. For questions related to Product, Security, Corporate, Privacy, Commercial Legal, and ESG which were not answered following the steps above, the Sales Team Member can open an Issue [here](#): be sure to select the RFP Intake Issue Template
1. When filling out the RFP Intake Issue Template please do the following:

- Select the box for the applicable Content Area(s); and
 - Delete the Content Area rows that are not applicable to prevent unnecessary notifications. Only the relevant DRIs should be tagged in the issue.
1. RFP Intake Issues will be assigned to applicable DRIs.

What Field Security Can't Do

There are parts of the Request for Proposal or Request for Information process that fall outside of Field Security's scope. We cannot write the proposals or provide the following: product or service specifications, implementation schedule, and plans; training or support specifications and terms; information surrounding GitLab's ability to provide the appropriate resources; other GitLab customers' experiences; and anything related to costs, values, pricing, payments, etc.

What we can do is respond to requests relating to security and facilitate other SME's responses to areas such as People/HR, Finance, Privacy, Commercial Legal, etc.

Helpful resources

While our team will do our very best to facilitate the process, there are some self-service resources to help you complete certain documents.

If you receive a Vendor Set Up Form, you can find more information [here](#).

If you need an NDA, you can find more information on obtaining one [here](#).

Please review our SLAs regarding the timelines for each type of customer assurance activity.

For any financial information, please use the Sales Team New Customer Form Resources which has all the relevant information including banking information for all GitLab entities. Also review the investor relations page for filings and financial results data.

Participants

The following GitLab groups participate in the shared RFP program:

- Legal Privacy, DRIs: @emccrann ; @Bronwyn
- Legal Operations, DRIs: @rinalen; @ktesh
- Legal, DRI: @mtaylor
- ESG, DRI: @slcline
- People Ops, DRI: @cgudgenov
- Security, DRI: @ayofan

Interested in participating? Contact @ayofan today!

SECTION: security/security-assurance/field-security/field-security-study.md

Overview

GitLab conducts an annual Field Security Study to document areas of concern or improvement identified with GitLab's enterprise security, market competitiveness, and ability to support its customers' needs. By assessing the perceived impact rating and providing clear and centralized insight on customer feedback to GitLab's leadership, we can drive cross-organizational alignment on a strategy to iterate on GitLab's product and security programs.

Reports are considered Internal

Frequency

Annually during Q4

Leadership Sponsor

TBD

DRI

The Field Security team is responsible for collecting and analyzing the data, crafting and validating potential solutions, and tracking future remediation activities.

Process

Data Collection

The data for this report is collected from various sources, including:

- Customer feedback delivered to Field Security as part of security questionnaires, customer calls, and other customer assurance activities
- Customer feedback delivered to internal departments such as Sales, Support, Security, Legal, Infrastructure, and Customer Success
- Competitor product comparisons to GitLab using publicly available data sources
- Third-Party Cyber Security and Risk reporting services such as BitSight and Qualys SSL
- Industry perception of GitLab security via media publishings (articles, blogs, & public forums)
- Concerns and results from the prior year's report

The quarterly Field Security research reports will be a primary input when developing the annual Field Security Study.

Data Analysis

The following analysis will occur based on the collected data:

- Evaluation of concerns from the prior year to include remediation status and updated considerations.
- Evaluation of current areas of customer concern.
- Competitive analysis to include a comparison of available security features, security features maturation and security compliance offerings.
- Documentation of recommendations based on field feedback. Note, these should not be

considered the final plan for remediation as that will be the responsibility of the GitLab DRI to define.

Reporting and Remediation

A detailed report is produced and provided to relevant internal stakeholders for consideration. Prioritized concerns will also be documented in GitLab issues by the Field Security team and assigned to the appropriate team members.

- Information Security related issues will be evaluated and managed by Security Leadership.

Listing of Reports (Internal Only)

- FY21 GitLab.com Field Security Study report and Epic
- A Field Security Study report was not delivered for FY22.
- FY23 Field Security Study report.

```
<div class="d-grid gap-2 my-4">  
<a href="https://handbook.gitlab.com/handbook/security/security-assurance/field-security/"  
class="btn bg-primary text-white btn-lg">Return to the Field Security Homepage</a>  
</div>
```

SECTION: security/security-assurance/field-security/field_security_observation_and_ofi_quality_guide.md

Purpose

This guide is designed to establish the quality expectations for observations and OFIs identified and documented by Field Security.

Scope

This quality guide covers observations and OFIs identified by Field Security through customer assurance activities in accordance with GitLab's observation management program.

Quality expectations

Field Security observations and OFIs should have the following characteristics:

- Contain enough detail for any team member to gain a fundamental understanding of what is being reported
 - What was identified?
 - Who was the prospect, customer, competitor, etc. that lead to the identification?
 - When was this identified?
 - How does this currently impact GitLab, or how could this impact GitLab in the future?
 - Why is this important, and why should we allocate resources towards it?
 - What can we do to remediate the problem, improve the solution, or position ourselves to take advantage of the identified situation?

- Be assigned to the appropriate team member for triage
- Have a proposed due date
 - This can be based on a clear deadline (e.g. the date a new regulation goes into effect), or it can be an estimate based on the perceived level of effort required to implement a solution.
- Be material in nature. For example, these identifications may:
 - Result in a financial impact for GitLab
 - Be the result of a new or updated compliance obligation for GitLab
 - Result in a competitive advantage for GitLab
 - Help us better support customer requests and expectations

Note Field Security observations and OFIs should be created in accordance with observation creation procedure.

SECTION: security/security-assurance/field-security/fsstp.md

Why a security sales training program?

One of Field Security's critical missions is to improve internal and external awareness of GitLab's security practices and the security of our platform. As we continue to iterate and grow, we must improve our ability to engage and impact prospects and customers in a meaningful way.

The Sales organization is a central part of this initiative. They have the critical role of selling GitLab and being trusted advisors to customers and prospects alike. From a security perspective, this role is critical from two angles:

- As the first DevSecOps platform, security is a central reason why prospects chose GitLab and want to natively integrate security into their development process
- As company supply chains are becoming more complex, security stakeholders are often central to the sales process. Showcasing the maturity of our internal security program is therefore a great competitive advantage.

The goal of the security sales enablement program is to focus on fulfilling these objectives using the approach detailed in the next sections.

Program presentation

{{< youtube "IjjukAdk" >}}

5 Objectives

Embed Security early

> Help the Sales stakeholders proactively engage with customers/prospects about security

Streamline Security work

> Reduce the administrative burden linked to customer security review processes

Understand Security's role

> Strengthen the understanding of the customer assurance activities and Field Security work

Help better position Security

> Guide Sales in positioning our security documentation and resources to shorten the cycle

How to reach Security?

> Know where to go and who to reach out for questions, support and escalations

Holistic security training and enablement

{{% details summary="1. Throughout the pipeline" %}}

- At the discovery stage
- During scoping discussions
- With the technical evaluation
- When drafting the proposal
- In the negotiation stage

{{% /details %}}

{{% details summary="2. During their time at GitLab" %}}

- Before they join GitLab
- During the onboarding process
 - Sales Quick Start
 - 30-60-90
- At each milestone of their career at GitLab
 - After a promotion
 - When expanding territory

{{% /details %}}

{{% details summary="3. Across the different roles" %}}

- SDR/BDR
- Account Executives
- Strategic Account Leaders
- Solutions Architect
- Customer Success Managers
- Professional Services
- Support Roles
 - Legal
 - Product Marketing

{{% /details %}}

{{% details summary="4. In every territory" %}}

- EMEA

- APAC
 - AMER
 - Dedicated Markets
- {{% /details %}}

{{% details summary="5. For every type of customer" %}}

- SMB
 - Mid-Market
 - Enterprise
 - Public Sector
- {{% /details %}}

Next generation of sales security training

Our objective is to build the next generation of GitLab's Field Security program. Part of enhancing this program is establishing a Security Sales Training and Enablement program. We want to spearhead the following initiatives:

- GitLab Security on Demand, the Netflix of sales security enablement
- Just in time micro-enablement, learn what you need, when you need it
- AI-powered AnswerBase, the companion to your security conversations
- Customer-focused Security Enablement sessions, building proficiency in the topics your prospects care about
- Integrated feedback process, so we can always improve the program to suit your needs
- Handbook-first comprehensive documentation, only a handbook page away from the information you need

Contact us

- sec-fieldsecurity Slack channel
- On Slack please feel free to tag @ayofan or @field-security

SECTION: security/security-assurance/field-security/independent_security_assurance.md

Overview

GitLab contracts with third parties to conduct annual network and application penetration testing and perform continuous public security scanning (BitSight). Evidence of these are shared via our Customer Assurance Package.

Third Party Security Ratings

BitSight is a third party security rating platform that utilizes public information collected across multiple domains to provide a numeric score from 250-900 (similar to a credit rating, but security focused). GitLab publishes three reports using BitSight:

- GitLab Production- this report represents the security posture of any URL or IP associated

with supporting our production architecture. Our goal is to maintain a rating of 700 or higher. Alerts from BitSight are monitored in real time and addressed as part of our Vulnerability Management program.

- GitLab Sub-Production- this report represents the security posture of any URL or IP that does NOT support the Production Environment noted above. This generally includes test environments and/or environments that are purposely kept out-of-date for quality assurance activities. This score is not monitored by GitLab and does not represent GitLab's Security Posture.

- GitLab User-Managed- many of our customers utilize static pages as part of gitlab.io. These pages are managed solely by our customers. However, from time to time, these pages are associated with GitLab erroneously. As such, we have moved any page on the GitLab.io domain to this report. This score is not monitored by GitLab and does not represent GitLab's Security Posture.

A copy of the Quarterly BitSight report and other Security Assurance artifacts are available to download in our Customer Assurance Package.

Third Party Vulnerability and Penetration Tests

SaaS

Customers are NOT authorized to conduct Vulnerability Scans or Penetration tests on GitLab's SaaS Application. A penetration test determines whether or not defensive measures employed are strong enough to prevent security breaches. If our Customers or Prospects were to attempt their own penetration testing of our SaaS environment, it could appear as a real incident to GitLab. For more information, please review GitLab's Terms of Service.

GitLab conducts external, independent penetration tests of our production architecture at least annually. In lieu of this, a report of our Annual Penetration Test is available in our Customer Assurance Package.

GitLab maintains a comprehensive Vulnerability Management program that is configured to identify vulnerabilities throughout our production architecture. Details are available within our Vulnerability Management handbook page.

Self-Managed

Penetration testing and Vulnerability scanning performed by self-managed customers must utilize the standard omnibus deployment to prevent false positives based on custom configurations. Automated vulnerability scanners commonly produce low priority issues and/or false positives. Before submitting the results from a scanner, please take a moment to confirm that the reported issues are actually valid and exploitable. Identified and validated vulnerabilities can be submitted through our HackerOne reporting program or by creating an issue for our security team.

<div class="d-grid gap-2 my-4">

Return to the Field Security Homepage

</div>

SECTION: security/security-assurance/field-security/knowledge_base.md

What is the knowledge base?

The knowledge base is a library of question and answer pairs related to GitLab, Inc. and the GitLab solutions. The knowledge base is a living library that is updated and expanded by questionnaires from our prospects and customers. These questionnaires are related to efforts such as RFX requests, third party risk assessments, and supplier due diligence requests. The knowledge base is designed to serve both Field Security and all other team members.

How can I use the knowledge base?

You can use the knowledge base in a manner similar to any other digital or physical library, to answer questions and conduct research.

The knowledge base is a self-service tool that enables you to quickly search for keywords related to topics of interest from our prospects and customers. Your searches will produce a list of question and answer pairs that closely match your keywords, providing you with the information you need to confidently respond to prospects and customers.

What are some use cases for the knowledge base?

- Preparing talking points for a prospect or customer meeting
- Responding to an email from a prospect or customer; and
- Learning more about the GitLab solutions and how we operate internally at GitLab, Inc.

How does Field Security use the knowledge base?

- To increase our efficiency and effectiveness when executing Customer Assurance Activities

How can I access the knowledge base?

The knowledge base is powered by our Trust Center tool, SafeBase.

Please check out this page to learn more about how to navigate the Knowledge Base!

When you have Knowledge Base viewer access, you will also be able to access the Q&As through Slack! Just type /kb-search security keywords into any Slack channel to view potential answers. A link is available to view the entries in SafeBase as well.

Of course, everyone can always query the Knowledge Base regardless of their access level by browsing it directly from the Trust Center.

Maintenance and Improvements

The knowledge base is a living library that is continuously being updated and expanded. As Field Security completes questionnaires, the base libraries are updated with current and accurate answers. Field Security updates the structure and tagging within the knowledge base in an ad-hoc manner to ensure The knowledge base remains an easy to navigate and effective self-

service tool for all team members.

If you have suggestions for improvements, please reach out to Field Security via any of the contact methods listed below.

Contact the Field Security Team

- Email
 - fieldsecurity@gitlab.com
- Slack
 - Feel free to tag us with @field-security
 - The sec-fieldsecurity, sec-assurance, security-division slack channels are the best place for questions relating to Field Security (please add the above tag).

```
<div class="d-grid gap-2 my-4">
```

```
  <a href="/handbook/security/security-assurance/" class="btn bg-primary text-white btn-
```

```
lg">Return to the Security Assurance Homepage</a>
```

```
</div>
```

SECTION: security/security-assurance/field-security/qbrs.md

Overview

GitLab conducts Quarterly Business Reviews during the first month of every quarter to review performance and lessons learned from the prior quarter, review forecasting, and prioritize requests that will help in future sales activity. In the spirit of Transparency and Collaboration, the Field Security participates in the QBR process to gather information and recommendations for future security related concerns.

Process

1. As part of the Field Manager QBR Roll Out schedule, Field EBAs will send a calendar invitation to the Field Security Team. Based on availability, members of the team will sign up for various QBR sessions.

1. Field Security team members will intake any security-related concerns or issues.

1. Field Security team members will evaluate the concerns and rate them using GitLab's Observation Management procedure.

1. A summary issue is shared to relevant stakeholders for consideration. As applicable, security concerns may be added to the Annual Field Security Study.

SECTION: security/security-assurance/field-security/trust_center_guide.md

Are you looking for GitLab's Trust Center?

```
<div class="d-grid gap-2 my-4">
```

```
<a href="https://trust.gitlab.com" class="btn bg-primary text-white btn-lg">GitLab's Trust
```

Center (Click Here!)
</div>

Do you have 120 seconds to learn more about the Trust Center?

{{< youtube "uOURJS7jpBw" >}}

GitLab offers Trust Centers tailored to customer needs

- GitLab.com page:

This page provides detailed security information to prospective and existing GitLab.com SaaS and self-managed customers for completing vendor security assessments.

- GitLab Dedicated page:

This page provides detailed security information to prospective and existing GitLab Dedicated customers for completing vendor security assessments.

Two types of Trust Center documentation

- Readily available information: The first step on the trust journey, these documents are publicly available and are designed to introduce GitLab's approach to security. Directly available from the Trust Center.

- Information under NDA: These documents provide detailed security information to prospective and existing customers for completing vendor security assessments. Due to the sensitive nature of the documentation, an NDA is required to be in place prior to viewing specific documents (such as SOC 2 Type 2). The NDA signing process will happen directly through the Trust Center.

Due to the nature of some of GitLab's security reports, certain documents on the Trust Center are only available once an NDA has been signed through the clickwrap process on the Trust Center.

Requesting new collateral for the Trust Center

To request new or updated Trust Center collateral, click the button below:

<div class="d-grid gap-2 my-4">
New or updated Trust Center collateral
</div>

SME owned collateral

For collateral owned by SMEs outside of Field Security, we perform an annual review and maintenance session. SMEs are notified via a GitLab issue and assigned relevant collateral pieces for review and maintenance. Upon completion, the updated collateral pieces are added to the appropriate CAP and prepared for publishing.

Additional support

If you have any further questions, please follow the below steps:

- Prospective Customers: Please fill out a request and a representative will reach out to you.
- Current Customers: Please contact your Account Owner at GitLab. If you don't know who that is, please reach out to sales and ask to be connected to your Account Owner.
- GitLab Team Members: Contact the Field Security team using the Customer Assurance workflow in the sec-fieldsecurity slack channel.

```
<div class="d-grid gap-2 my-4">  
<a href="https://handbook.gitlab.com/handbook/security/security-assurance/field-security/"  
class="btn bg-primary text-white btn-lg">Return to the Field Security Homepage</a>  
</div>
```

SECTION: security/security-assurance/governance/_index.md

Governance and Field Security team charter

{.h2}

<i class="fas fa-bullseye" style="color:rgb(110,73,203)" aria-hidden="true"></i> Mission

The 'G' in GRC, GitLab's security governance discipline helps to define, train and measure security strategies and progress towards security objectives by creating a set of processes and practices that run across departments and functions. By following a Governance framework, GitLab ensures accountability, fairness and transparency in how the company runs and how it communicates with its stakeholders.

<i class="far fa-lightbulb" style="color:rgb(110,73,203)" aria-hidden="true"></i> Core Competencies

These are the core responsibilities of the security governance discipline.

Security policies and standards

Keeping the organization on track and within established boundaries to ensure compliance with applicable laws and regulations while maintaining GitLab's Information Security Policies. Providing guidance, consistency and accountability to streamline internal processes and align with GitLab's values and mission.

Security handbook maintenance

Security Governance is responsible for the continuous maintenance and improvement of the security section in GitLab's handbook. This includes the creation and maintenance of controlled documents, maintenance of the security section's overall structure, content relevance and accuracy, and alignment with GitLab's style guide. To request an update to the handbook's security section, please open an issue using the link below.

[Security Handbook Request](https://gitlab.com/gitlab-com/gl-security/security-assurance/governance/security-handbook/-/issues/new?issuabletemplate=securityhandbookrequest)

Security Assurance metrics

Security Governance supports the development, implementation, and maintenance of metrics across the Security Assurance department.

Regulatory and compliance landscape monitoring

To support GitLab's regulatory and compliance requirements, the Security Governance team conducts quarterly monitoring for changes to such requirements. Material changes are reported to relevant team members for triage and action.

GCF Control Maintenance

Maintenance of the GCF control framework to include language, policy mapping, and relevancy updates.

Security Compliance Training

Creating and managing security compliance trainings to ensure GitLab team members are aware and trained in security core competencies.

GRC Application Administration

Managing a variety of tools used by the Security Assurance Team to support our day to day processes and strategic initiatives.

- Configuration changes
- User Access Management
- Upgrades/patching/incidents/restores
- High-Level quality oversight
- etc.

We will assist in managing and providing guidance to carry out day to day activities related to the core competencies of all compliance activities within Hyperproof such as Control Testing, UARs, Vendor Reviews and Risk Assessments. We strive to automate, integrate and streamline business processes to increase GitLab's Information Security Program maturity and deliver measurable ROI.

<i class="fas fa-id-card" style="color:rgb(110,73,203)" aria-hidden="true"></i> Contact the Team

Joe Longo, @jlongogitlab, Senior Manager, Governance and Field Security

- Controlled Documents
- Security compliance training
- GCF control maintenance

- Regulatory and compliance landscape monitoring
- Security handbook maintenance

<i class="fas fa-book" style="color:rgb(110,73,203)" aria-hidden="true"></i> References

- Security Compliance Controls
- Controlled Document Procedure

[>Return to the Security Assurance Homepage](/handbook/security/security-assurance/)

SECTION: security/security-assurance/governance/automation-library.md

Has this been automated for the team yet?

This page is intended to provide a jumping off point for what components of Security Assurance have been automated and are available for use by team members. It includes ad-hoc automations that should be run by team members whenever desired as well as ongoing scheduled automations in place.

Each automation includes a brief description of available functionality and links to a relevant project. Detailed guidance on how to run the automations including inputs to pipelines etc. are available in detailed READMEs for each automation as needed.

If you have more ideas about what could be automated, please open an issue in the Security Assurance Automation project.

Layout

Each automation added to this page should contain the below details at minimum:

- Header title as anchor
- Brief Description
- Repository Link (may be a private/limited access project)
- Best Point of Contact for Questions

What is in place and always running?

Authomize Sync

- This automation syncs user listings from various systems into Authomize (User Access Review Tool) on a daily basis. A manual sync can be triggered if required.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Hyperproof Task Sync

- This is a two way sync between Hyperproof Tasks and GitLab Issues that scans for changes

every 5 minutes and syncs to keep both data sources up to date.

- Primary GitLab Project Link
- Contact:
 - Donovan Felton - Security Assurance Engineer
 - James Sandlin - Staff Security Assurance Engineer

Escalator Engine

- This automation takes a defined ruleset for a specific project and leaves a comment to "escalate" issues that meet the defined criteria such as open issues without specific labels, open issues past due etc. If you'd like to set this up for another project, just reach out!
- Primary GitLab Project Link
- Contact:
 - Donovan Felton - Security Assurance Engineer
 - James Sandlin - Staff Security Assurance Engineer

Automated Testing of CM-5 (Testing for Project Settings to enforce SOD)

- This automation generates a testing workbook on a weekly basis with details of which projects in a curated list of critical projects are configured in a way to enforce SOD for repository changes by reviewing MR Approvals, Approval Rules, and Protected Branch settings. The output is an excel workbook with details of which individual settings caused any noted failures where SOD wouldn't be enforced.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

User Access Review Listing Requests

- This automation generates UAR listing requests for those systems unable to be/not yet integrated into Authomize (User Access Review Tool). The schedule for requests is defined per listing and issues are automatically assigned to the correct team members for actioning.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Audit Support Requests

- This automation generates issues with requests/milestones/action items associated with audit activities. The schedule for issues that are created is defined per issue to be created and issues are automatically assigned to the correct team members for actioning.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Recurring Team Action Issues

- These automations generate issues on a weekly basis to track weekly action items, highlights and other recurring work activities.
- Project Links
 - Risk Team
 - Commercial Compliance
- Contact: Byron Boots - Senior Security Assurance Engineer

What can I run ad-hoc?

Feedback Bot

- This automation enables team members to send private feedback to other team members through Slack.
- Primary GitLab Project Link
- Contact: Donovan Felton - Security Assurance Engineer

GitLab Export

- This automation allows users to generate listings of Accounts, Deployments, Issues, Label Usage, Group/Project Members, and Personal Access Tokens in an easy to use .csv format.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Automated Access Request Issue Creation

- This automation consumes a completed UAR output from our Access Review tool and parses the information into a standardized GitLab Issue Access Request for actioning by the appropriate systems owner.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Automated Terminated Access Review

- This automation consumes a UAR output from our Access Review tool and performs a review for terminated users against team member and contractor records. Account details are populated for strongly matched identities and weakly matched identities have found details compiled for ease of review.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Audit Events Listing

- This automation generates a list of all audit events for a given project in defined time period. When run, the automation also flags Audit Events that may impact SOD settings for a project for closer review. The report outputs into an easy to use excel format.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Merged MRs Listing

- This automation allows users to generate listings of GitLab MRs for a desired project in a defined time period with the output into an easy to use .csv format.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Closed or Open Issues Listing

- This automation allows users to generate listings of GitLab Issues for a desired project in a defined time period with the output into an easy to use .csv format.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Automated Testing of CM-3 (Test for MRs with SOD violations)

- This automation allows users to generate a testing workbook for a project in a given time period with details on whether MRs that were merged contained SOD violations such as a user making changes to an MR after approvals were captured without requesting a new review.
- Primary GitLab Project Link
- Contact: Byron Boots - Senior Security Assurance Engineer

Related Resources

- Security Assurance Automation Team Page

 I have questions

- Donovan Felton, @dfelton, Security Assurance Engineer, Automation
- James Sandlin, @jsandlin, Staff Security Assurance Engineer, Automation
- Byron Boots, @byronboots, Senior Security Assurance Engineer, Compliance

SECTION: security/security-assurance/governance/phishing.md

{{% alert color="danger" title="Alert" %}}

If you suspect you've received a phishing email and have not engaged with the sender, please see: What to do if you suspect an email is a phishing attack.

If you have engaged a phisher by replying to an email, clicking on a link, have sent and received text messages, or have purchased goods requested by the phisher, please engage the Security Engineer on-call.

Further information on GitLab's security response program is described in our Incident Response guide.

{{% /alert %}}

Phishing Program

The GitLab Phishing Program is designed to educate and evaluate GitLab's ability to detect and prevent phishing attempts. The goal of the program is to maintain up-to-date educational materials, provide ongoing training, and execute real-world simulations to provide GitLab Team Members the knowledge to identify, report, and block phishing attempts. Phishing simulations are provided by ProofPoint, GitLab's third party provider, and will help satisfy external regulatory requirements and bolster customer assurance.

The Security Governance team coordinates with the following teams before a phishing simulation exercise:

- Security Incident Response Team (SIRT)
 - Responsible for triaging phishing emails
 - If they are made aware of a simulation they will provide the team member with additional instructions
- IT Operations/Team Member Enablement
 - Owner of GSuite (GitLab's email platform)

Phishing Simulation Campaigns

Phishing simulations are an integral part of our overall security awareness education. The Security Governance team utilizes ProofPoint to generate and send simulated phishing emails to GitLab team members to assess their ability to identify phishing attempts. The goal is that TMs either report the phishing attempt (ideal behavior) or delete the email (acceptable behavior). TMs who click the link will automatically be assigned a phishing-specific training module, also via ProofPoint.

When will phishing simulations occur?

At a minimum, one phishing simulation campaign will take place each fiscal quarter. Prior to the phishing campaign's start, a general notification to the GitLab organization will be posted to the whats-happening-at-gitlab Slack channel. However, for maximum efficacy, the exact content, date, time and team members receiving the email will not be communicated. Campaigns may contain various versions of the simulated email that will be delivered at random times throughout the 1-week campaign.

Who will receive the phishing simulations?

All GitLab team members, contractors and others with access to production data will be included in the quarterly campaigns with the exception of any individuals on extended leave at the time the campaign is launched.

What will a phishing simulation email look like?

The phishing simulation email from ProofPoint will appear as though it is originating from GitLab or a fictitious company. This email will look realistic/authentic in the attempt to engage the TM to click a link. We would love to show you what this looks like but that would defeat the purpose of the test.

How should I respond to the phishing simulation?

Just like with any suspected phishing or malicious email, follow the handbook process for reporting suspected phishing emails. The preference for reporting phishing emails is Option 1 via PhishArm.

What happens if I click the link?

In the event the link is clicked, the team member will be redirected to a landing page

notifying them that this was part of a simulation. TMs will see a quick Teachable Moment and will be automatically enrolled in a short training assignment (also provided by ProofPoint). We want everyone to be as successful as possible and these quick trainings will guide and provide a few tips to help recognize malicious emails in the future. The trainings are quick interactive videos and completing them will help us with future training assessments.

Training Module

Our phishing partner, ProofPoint, curates and hosts the training modules which will be assigned upon when the link is clicked. The training is designed to reinforce and provide real world examples of detecting and reporting phishing. We highly encourage you to complete the training soon after being received as this will help to reinforce and better prepare you to spot phishing attempts in the future. The training modules are short and interactive and will be coming from awareness@securityeducation.com.

If the training is not completed within 1 week, a reminder will be sent from ProofPoint. If required, the Security Governance team will communicate incomplete assigned training modules to managers for assistance with completion. Demonstration of completed training supports compliance with the Phishing program and will strengthen our regulatory requirements.

Simulation Result Outcomes

Action	Outcome
Submitted email via PhishArm or directly to phishing@gitlab.com	No further action.
Did nothing with the email	No further action.
Clicked on the link	Training will be assigned

Phishing Simulation and Training Metrics

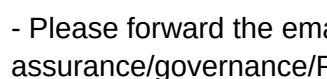
The Security Governance team will initiate and track the quarterly phishing simulation campaign within ProofPoint. Once the campaign has completed, the Security Governance team will provide non-identifying results in the Phishing Program project.

Questions and Answers

I clicked the link in the email, what do I do?

- Please complete the required training module you have been assigned as soon as possible. Knowing this is a phishing simulated email, please avoid discussing with anyone else or feel compelled to post a screenshot of the email received in Slack as it may skew the results of the phishing exercise.

I didn't click the link in the email, what do I do?

- Please forward the email via the  or as an attachment to phishing@gitlab.com using these instructions. Knowing this is a phishing simulation, please

avoid discussing with anyone else or feel compelled to post a screenshot of the email received in Slack as it may skew the results of the phishing exercise.

I got assigned training without clicking the link in the email, what do I do?

- Please reach out to Security Governance @sec-governance to report and review the steps that were taken prior to receiving the training to identify if this should be considered a false positive. There are ways that the link can get triggered even if not directly clicked in the phishing email. Security Governance can help troubleshoot what might have happened.

NOTE

- If the link provided in the phishing email is NOT clicked, but copy/pasted, that could also trigger the 'click', please refrain from trying to decipher the link.
- If Option 3 is used to report an email, this could also trigger the 'click' as the tracking image could be cached by the ATP and proxy services.

Feel free to complete the assigned training and consider it as taking an extra step to stay secure!

I use a physical Yubikey for multifactor authentication, why did I still fail the phishing simulation?

- While a physical Yubikey or other token device used will prevent you from fully being phished, not all GitLab systems support these devices. As this simulation exercise is for training and awareness, the goal is to test how GitLab team-members respond to these emails.

I thought the Red Team was conducting the phishing exercises?

- Correct! The Red Team was conducting our phishing exercises with a tool they built but unfortunately Google began identifying the exercises as malicious and were shutting them down quicker with each attempt. This caused the phishing exercises to not be beneficial along with no results to work with.

Why are we using an external vendor?

- Due to our internally created solution being identified as malicious by Google, we needed to utilize an external solution that would be able to provide a consistent process and reliable results, which resulted in our partnership with ProofPoint.

Who decides who receives these phishing simulations?

- All GitLab team members, contractors and others with access to production data will be included in the quarterly campaigns with the exception of any individuals on extended leave at the time the campaign is launched.

How often will I receive these?

- At a minimum, one phishing simulation campaign will take place each fiscal quarter. Prior to the phishing campaign's start, a general notification to the GitLab organization will be posted

to the whats-happening-at-gitlab Slack channel. However, for maximum efficacy, the exact content, date, time and team members receiving the email will not be communicated. Campaigns may contain various ve